

CYBERSECURITY / GRC

CYBERSECURITY GOVERNANCE FRAMEWORK FOR THE AUSTRALIAN ENERGY MARKET OPERATOR

A deep dive into AEMO from a GRC perspective

OCTOBER 2026

Introduction

This report analyzes AEMO's cybersecurity governance and management practices against NIST CSF 2.0, COBIT 2019, ISO 27001 and more. AEMO is treated as a SOCI-relevant critical infrastructure organization because the energy sector is regulated under the Security of Critical Infrastructure Act 2018, and "critical energy market operator assets" are recognized within the energy critical infrastructure asset classes.

Organizational Overview and Cyber Risk Context

The Australian Energy Market Operator (AEMO) works within one of the most security sensitive industries within Australia; the energy sector. The business activities of AEMO revolve around the reliable running of the electricity and gas networks, the accuracy and integrity of market and operational data, and the coordination within market players, government, suppliers and industry. Within such an environment, cybersecurity governance is not just an IT management process. It is a core enterprise governance function that supports business continuity, market confidence, regulatory compliance and national resilience.

Cybersecurity thus for AEMO exists as part of a wider governance, risk, and compliance environment. An event involving the computer networks of the AEMO will have ramifications well beyond just system interference, such as delayed market operations, loss of confidence in energy information, reporting responsibilities, disruption in industrial collaboration, and more. The framework uses Initial maturity as its starting planning baseline, to be established through control assessment and organisational evidence. This baseline places emphasis on formalising governance, documenting processes and measuring cybersecurity performance against business outcomes [1]. The purpose of the framework is to develop a disciplined, risk-oriented, and measurable cybersecurity governance framework that will enable AEMO to reach Defined and Managed maturity within 18 months.

The proposed operational structure comprises six branches: head office based in Melbourne; four national branches in Australia based in Sydney, Brisbane, Perth and Adelaide; and one international branch based in the United Kingdom, London. The proposed branch structure poses a unique governance issue for AEMO. There should be one cybersecurity baseline that applies to the entire organization, but there should also be cybersecurity compliance overlays by the branch. Each of the branches in Australia must comply with SOCI expectations, as well as the Australian Privacy Act and ASD ISM expectations [2], [6]. The London branch must follow the enterprise baseline while also applying to the UK GDPR, the UK Data Protection Act 2018 and [4], where relevant, EU GDPR requirements for European personal

data [5]. AEMO's cyber governance overview is also detailed in the image below to demonstrate how everything is connected through a cyber governance framework.

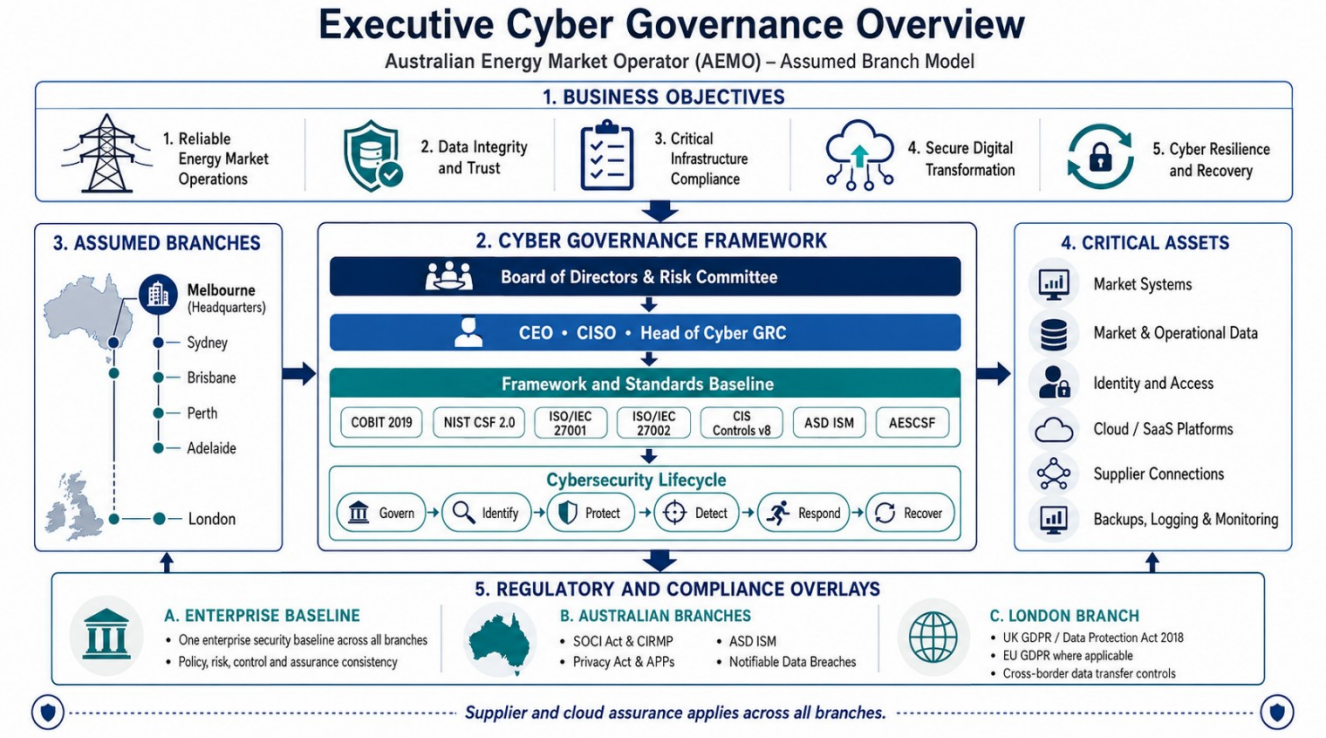


Figure 1: Executive cyber governance overview of AEMO

Organizational Operating Model and Governance Scope

The six-location operating model adopted for this framework calls for federated cybersecurity governance. Policies, risk appetite, reporting practices, compliance considerations and assurance demands need to be established at Melbourne-based headquarters and applied to all branches, whether national or international. All branches need to have the same level of controls, evidence and reporting practices concerning cyber risks and consistent escalation model.

Branches cannot be allowed to operate under loose governance arrangements just because they are smaller or more distant from headquarters. For AEMO, which derives its value from reliable information flow and decisions, any weaknesses in cyber protection at a branch can spill over to identity management, cloud storage, collaboration platforms, vendor connections and databases. In this case, branch-based cyber governance is an enterprise-level risk, not an administrative one.

Branch	Business Role in the Framework	Main Governance Implication
Melbourne Headquarters	Board, executive leadership, enterprise cyber governance, market systems oversight	Owns cyber risk appetite, policy approval, SOCI coordination, board reporting and enterprise assurance
Sydney Branch	National stakeholder and market participant engagement	Implements enterprise controls, protects market participant communications and reports local risks
Brisbane Branch	Regional operational support and energy coordination	Maintains local continuity processes, secure access and branch incident escalation
Perth Branch	Western Australian operational support	Requires resilience planning, backup assurance and region-specific recovery evidence
Adelaide Branch	Renewable integration and regional market support	Requires strong change of governance, data integrity and supplier security controls
London Branch	International collaboration, vendor/research coordination and European data handling	Requires enterprise baseline plus UK/EU privacy governance, data transfer controls and supplier assurance

Figure 1 and the table above support accountability, and details cyber governance posture of AEMO. Melbourne headquarters owns the governance framework, but every branch owns implementation evidence. The Head of Cyber GRC should maintain the central framework, while branch cyber coordinators provide quarterly attestations covering asset inventory, privileged access, vulnerability remediation, incident readiness, supplier risks and local exceptions.

Critical Infrastructure and Framework Design Rationale

The cybersecurity strategy adopted by AEMO needs to consider the critical infrastructure nature of the organization. A standard security strategy will not suffice since the impact of failure is far more serious than that associated with a corporate business environment. The major impacts of cybersecurity for AEMO include system availability, data integrity, controlled access, secure supplier connections, and incident management [1].

This framework consists of various governance-related and technical standards because none of the available guidelines is complete with regard to the particular environment in which AEMO works. The governance framework in COBIT 2019 is used due to the differentiation between governance and management activities and the ability to establish board governance based on goals, accountability, and performance. NIST CSF 2.0 framework serves as the practical basis that comprises govern, identify, protect, detect, respond, and recover phases [3]. ASD ISM represents the Australian approach to risk-based security controls [2]. ISO/IEC 27001 and ISO/IEC 27002 frameworks offer internationally accepted information security management systems and control requirements [3]. CIS Controls v8 allows implementing various practical controls like inventory management, secure configuration, MFA, logging, vulnerability management, and incident response procedures [7]. NIST SP 800-55 contributes to measuring by mandating the assessment of cybersecurity performance via meaningful measures instead of assumptions [8].

Source	Role in the Framework	Reason for Inclusion
SOCI Act and CIRMP expectations	Critical infrastructure risk management and incident reporting	Required for Australian energy-sector governance
ASD ISM	Australian government-aligned cybersecurity control guidance	Supports risk-based Australian control selection
AESCSF	Energy-sector maturity and resilience reference	Aligns cyber maturity with energy-sector expectations
COBIT 2019	Board of governance, management objectives and accountability	Connects cyber risk to enterprise governance
NIST CSF 2.0	Cybersecurity lifecycle structure	Organizes Govern, Identify, Protect, Detect, Respond and Recover
ISO/IEC 27001	ISMS governance model	Supports consistent enterprise security management
ISO/IEC 27002	Control domains and policy guidance	Supports policy and control development
CIS Controls v8	Practical implementation safeguards	Converts governance goals into measurable actions
NIST SP 800-55	Security metrics and measurement	Supports KPI design and performance reporting

UK GDPR / Data Protection Act	London branch privacy compliance	Supports lawful data handling and breach governance

Philosophically, the framework in the table above [2], [3], [4], [5] is designed not to have any "stacking" that does not serve an intended purpose. There is a defined use case for each standard. For instance, COBIT provides information on who the controller and performance regulator for AEMO is. The NIST CSF categorizes what cybersecurity outcomes are required. ISO 27001/27002 gives management system discipline and control domains. CIS controls offer actionable implementation steps. The ASD ISM and SOCI provide country-specific requirements for Australia. Privacy laws add jurisdiction-specific obligations for personal data. And the UK GDPR Act is for the London branch of AEMO to bring the organization under local privacy compliance law of data handling and breach governance [2], [3], [4], [5], [6].

Strategic Alignment with Business Objectives

The cybersecurity strategy should have direct relevance to the business goals of AEMO. The business of the organization is not just office work, but is much more involved and includes market coordination, operational information processing, forecasting, planning, interactions with participants and reliable communication within the industry. Consequently, cybersecurity should first focus on protecting the infrastructure that is necessary for market reliability, energy system visibility, operational decisions and stakeholder confidence.

One of the most important GRC considerations involves security versus operational effectiveness. In critical infrastructure organizations, controls cannot be implemented in a manner which will interfere with legitimate urgent activity, yet at the same time there is no possibility of letting convenience pose serious risks. For example, privileged access must be tightly controlled through MFA and privileged access management, but emergency access procedures must exist for time-critical operations. Similarly, vulnerability remediation must be disciplined, but patching must be coordinated with operational change windows to avoid unintended disruption.

Business Objective	Cybersecurity Governance Alignment	Practical Governance Response
Maintain reliable energy market operations	Prioritize availability of systems supporting electricity and gas operations	Critical asset register, resilience controls, recovery testing and continuity exercises
Preserve trust in market and operational data	Protect integrity and traceability of information used in decisions	Data classification, access controls, logging and change

		governance
Meet critical infrastructure obligations	Treat cybersecurity as board-level enterprise risk	CIRMP, SOCI-aligned incident reporting, risk appetite and board reporting
Support digital transformation and energy transition	Secure new platforms, APIs and suppliers before deployment	Secure-by-design reviews, supplier assurance and architecture governance
Build mature cyber governance	Move from reactive practices to measured and repeatable controls	Policies, KPIs, audit, branch attestation and maturity roadmap

Strategic alignment thus must be shown via executive reporting. The Board should receive not just technical briefings like malware discoveries or firewall events. Instead, it should get business-aligned reporting, like critical systems exposure, risks that exceed appetite, ability to recover from disruption, privileged user status, supply chain risk, critical vulnerabilities remediated, and results of cyber exercises. In this way, cybersecurity can be considered in the context of resilience and business risk instead of just technical actions.

Governance Structure, Roles and Accountability

AEMO needs to have a governance model where the board is provided visibility while the operations team acts swiftly. Centralized governance needs to be achieved from the Melbourne headquarters, yet the implementation process will be done in a distributed manner through all the branches. Ownership of the cybersecurity program and strategy rests with the CISO. The Head of Cyber GRC is responsible for maintaining the framework, policies, risk register, compliance mapping, and assurance plans. Branch cyber coordinators should act as local implementation and evidence owners.

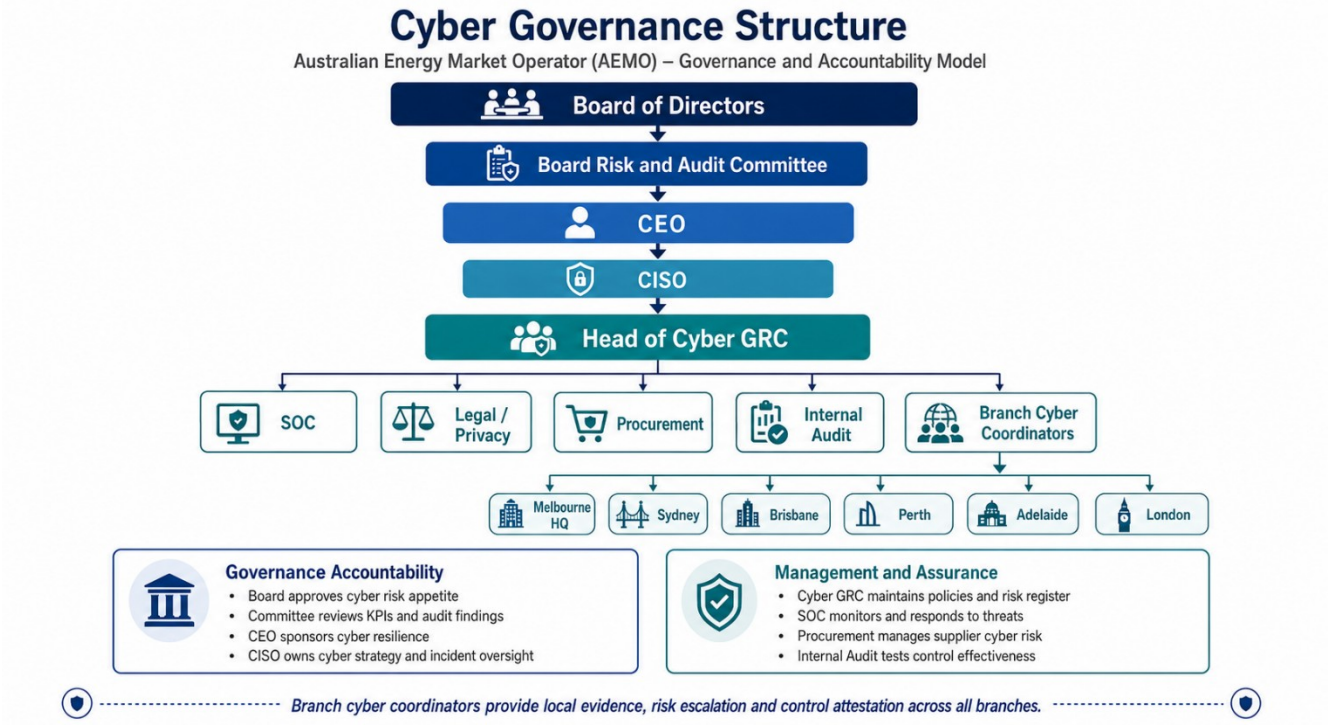


Figure 2: Cyber Governance Structure, Roles, Accountability of Aemo

A RASCI approach needs to be adopted for governance activities. The Board of directors is Accountable for risk appetite. The CISO is Accountable for program performance. Cyber GRC is Responsible for policy, risk, and compliance management. Branch cyber coordinators Support the process. The Legal department, Procurement department, Internal Audit, and System Owner are Consulted. Employees, contractors, and suppliers are Informed of responsibilities [9].

Role or Body	Accountability	GRC Purpose
Board of Directors	Approves cyber risk appetite, receives cyber risk reporting and supports resilience investment	Ensures cyber risk is treated as enterprise risk
Board of Risk and Audit Committee	Reviews KPIs, control exceptions, audit findings and material risks	Provides oversight and challenge
CEO	Sponsors cyber resilience and executive accountability	Links cybersecurity to business continuity and strategy
CISO	Owns cybersecurity strategy, control program and incident oversight	Provides accountable cyber leadership
Head of Cyber GRC	Maintains framework, policies, risk	Convert strategy into

	register, compliance obligations and assurance plan	repeatable governance practice
SOC Manager	Oversees monitoring, detection and technical response	Provides operational threat visibility
Branch Cyber Coordinators	Maintain local control evidence, coordinate branch risks and escalate incidents	Prevents branch-level governance gaps
Legal and Privacy	Advises on SOCI, Privacy Act, UK GDPR, EU GDPR and breach obligations	Reduces legal and regulatory exposure
Procurement and Vendor Management	Embeds cyber controls into supplier due diligence and contracts	Reduces third-party and supply-chain risk
Internal Audit	Tests control design and operating effectiveness	Provides independent assurance

This helps in overcoming an issue seen at initial maturity levels, which is lack of ownership. Without any ownership, a policy will simply become documentation. By applying accountability to processes, AEMO will be able to ensure acceptance of cyber risks by the appropriate business owner and that exceptions have time limitations [9].

Regulatory and Standards Applicability Across Branches

AEMO should apply one enterprise cybersecurity baseline across all branches, supported by local compliance overlays. This avoids fragmentation while still recognizing that Australian and international branches operate under different legal and regulatory expectations.

Layer	Applies To	Required Alignment
Enterprise Cybersecurity Baseline	All branches	COBIT 2019, NIST CSF 2.0, ISO 27001/27002, CIS Controls v8
Australian Critical Infrastructure Layer	Melbourne, Sydney, Brisbane, Perth and Adelaide	SOCI Act, CIRMP, ASD ISM, AESCSF, Privacy Act, Australian Privacy Principles, Notifiable Data Breaches scheme
London / UK Privacy Layer	London branch	UK GDPR, Data Protection Act 2018, privacy impact assessments, data transfer controls
EU Data Protection Overlay	London branch if processing EU personal	EU GDPR, cross-border transfer controls,

	data	processor due diligence
Supplier and Cloud Assurance Layer	All branches using third-party services	Contractual security clauses, incident notification, right-to-audit, ISO 27001/SOC 2 evidence where appropriate
US Technical Reference Layer	US-based vendors or technologies, where used	NIST CSF and NIST SP guidance as contractual or assurance references rather than branch law

Australia branches need to keep evidence regarding risk management obligations for SOCI. This obligation involves keeping information about critical assets, reporting cyber incidents via designated channels, managing business-critical data held or processed by other parties, and showing that both cyber and operational risks have been considered while creating a documented risk management program for critical infrastructure. In terms of GRC, Australian branches need to demonstrate proof of asset ownership, data classification, cyber incidents escalation, supply chain risk assessment, vulnerability fix and business continuity testing.

London office needs to adhere to the AEMO baseline for enterprise cybersecurity but implement privacy-specific requirements, including data minimization, lawful processing, access based on roles, data encryption, reporting breaches, handling data subjects' requests, vetting vendor processors and implementing documented transfer mechanisms if international data transfers are involved. London office might not be running any critical system for the market, but it can be involved in processing employee data, data from suppliers, research, stakeholders and collaborations. That is enough to require disciplined privacy governance.

US obligations should not be overstated because there is no assumed US branch. However, AEMO may still use US-based cloud, security or SaaS providers. In that case, US frameworks such as NIST CSF and NIST SP guidance should be used as assurance references in contracts and vendor reviews. For example, a US cloud provider may be required to provide ISO 27001 certification, SOC 2 Type II assurance or evidence of alignment with NIST CSF outcomes [2], [3], [4], [5], [6], [7].

Asset Identification and Risk Assessment

The underlying concept in the proposed framework is asset visibility. It will be impossible for AEMO to manage its cyber risk without knowing the systems, data, suppliers, and identities that underpin its essential business services. Asset identification should include technology assets, data assets, business services, people, suppliers and dependencies on operations. This includes market systems, planning systems, identity services, cloud services, API services, branch networks, collaboration services, backup services and monitoring services.

The risk assessment process must use a six-step approach. These steps are as follows. Step one involves identifying the boundaries and business service to be assessed. Step two involves identifying assets, data flows, users, suppliers, and technical dependencies. Step three is classifying assets based on their confidentiality, integrity, and availability requirements. Step four is identifying threats, vulnerabilities and controls. Fifth, assess likelihood and business impact. Sixth, assign treatment actions, owners, due dates and residual risk ratings.

Risk Scenario	Affected Asset	Business Impact	Treatment Direction
Ransomware affects market-supporting systems	Market operations platform	Operational disruption and loss of stakeholder confidence	Network segmentation, EDR, immutable backups and recovery testing
Privileged account compromise	Identity and access systems	Lateral movement across branches and cloud services	MFA, PAM, admin separation and access reviews
Supplier compromise	Cloud or SaaS service	Data exposure or service interruption	Vendor assurance, contract clauses, monitoring and exit planning
Data integrity attack	Market participant or planning data	Incorrect decisions and reduced trust in market information	API security, validation controls, logging and change approvals
London branch privacy breach	Staff, supplier or stakeholder personal data	UK/EU privacy breach, regulatory exposure and reputational harm	Privacy impact assessment, encryption, access control and breach workflow
Delayed vulnerability remediation	Branch systems and applications	Increased attacker opportunity and audit findings	Patch SLAs, risk-based prioritisation and exception approval
Poor incident escalation	Branch or supplier incident	Delayed containment and reporting failure	Branch playbooks, contact lists and annual exercises

The risk register needs to be dynamic and not static. Risks need to be added whenever there are significant changes in technology, change in vendors, move to the cloud, vulnerabilities, incidents, audits, or change of branches. The organization needs to escalate high-risk residual risks. Risk acceptance should be official, temporary, and have a responsible business owner approve it [10].

Cybersecurity Policies and Standards

The policy approach must transform governance intentions into actionable behavior. AEMO needs to maintain an appropriate governance hierarchy that comprises a board-approved Cybersecurity Governance Policy along with associated standards, procedures, playbooks, and evidence templates. This is necessary because Initial maturity often includes policy documents but lacks enforcement, measurement and branch-level implementation.

Policy or Standard	Minimum Requirements	Owner	Review Frequency
Cybersecurity Governance Policy	Defines cyber risk appetite, reporting, roles and branch accountability	CISO	Annual
Cyber Risk Management Standard	Requires risk assessments, risk owners, treatment plans and residual risk approval	Head of Cyber GRC	Annual
Asset and Data Classification Policy	Requires asset ownership, criticality rating, data labels, retention and disposal	Cyber GRC and Data Owners	Annual
Identity and Access Management Standard	Requires MFA, least privilege, PAM, quarterly access reviews and joiner-mover-leaver controls	IAM Manager	Six-monthly
Vulnerability Management Standard	Defines scanning, patch SLAs, remediation priorities and exception approval	Vulnerability Manager	Six-monthly
Logging and Monitoring Standard	Requires centralized logs, time synchronization, SIEM onboarding and retention	SOC Manager	Annual
Supplier Cyber Risk Policy	Requires due diligence, contractual clauses, annual assurance and incident notification	Procurement and Cyber GRC	Annual
Incident Response Plan	Defines CIRT, SEMT, escalation, evidence handling, reporting and communications	CISO	Annual and post-incident
Privacy and Cross-	Defines APP, UK GDPR, EU	Legal and	Annual

Border Data Policy	GDPR, data transfer, DPIA and breach requirements	Privacy	
Business Continuity and Disaster Recovery Standard	Requires RTO/RPO, backup testing, recovery exercises and alternate communications	Business Continuity Manager	Annual

The policies must contain clear control statements. Every instance of privileged access will have to implement MFA and privileged access management, except for those where documented exceptions are granted with the approval of the CISO. Every critical system will be required to register itself in the asset inventory and assign a system owner prior to being placed into production. All critical suppliers will need to pass cybersecurity due diligence checks before being onboard and at least once every year afterwards. Any high-severity cyber incident will have to follow the agreed upon escalation process. Every use of personal data at the London branch must be assessed for compliance with privacy and cross-border transfer laws.

Such comprehensive policy formulation is necessary since this is what demonstrates that governance is not just a set of lofty aspirations but concrete requirements. It defines who must do what, how evidence is created, who approves exceptions and how compliance is reviewed [11].

Implementation Plan

The implementation plan is structured over 18 months. The sequence prioritizes governance and visibility first because advanced tools cannot compensate for weak ownership, poor asset visibility or unclear risk acceptance.

Phase	Timeline	Actions	Evidence
Phase 1: Govern and mobilise	Months 1–3	Establish cyber steering committee, approve risk appetite, appoint branch cyber coordinators	Charter, RASCI, board minutes
Phase 2: Identify and assess	Months 2–6	Build assets, software, data and supplier inventories; classify critical services	CMDB, data map, supplier register, risk register
Phase 3: Protect critical services	Months 4–10	Implement MFA, PAM, secure baselines, patching, backup hardening and supplier controls	IAM reports, patch reports, backup evidence, supplier assessments
Phase 4: Detect and respond	Months 7–13	Onboard logs, tune SIEM, develop playbooks, define CIRT/SEMT	SIEM dashboard, incident runbooks, exercise report

		processes and run exercises	
Phase 5: Assure and improve	Months 12–18	Conduct internal audit, maturity reassessment, branch attestation review and remediation planning	Audit report, maturity scorecard, action register

The implementation should be risk-based. Market-supporting systems, identity platforms, privileged access, backup systems, cloud platforms and critical suppliers should be prioritized before lower-risk corporate systems. Branches should not be assessed only by whether they have adopted a policy, but whether they can produce evidence that the control is operating.

Metrics, KPIs and Performance Measurement

Cybersecurity performance should be measured through KPIs that show control effectiveness and risk reduction. AEMO's Board does not need raw technical volume metrics. It needs indicators that reveal whether critical risks are being reduced and whether the organization can prevent, detect, respond to and recover from material cyber incidents.

KPI	Formula	Target	Evidence Source	Owner	Escalation Trigger
Critical asset inventory coverage	Critical assets recorded / known critical assets	98%	CMDB and discovery tools	Asset Manager	Below 95%
Privileged MFA coverage	Privileged accounts with MFA / total privileged accounts	100%	IAM/PAM reports	IAM Manager	Any gap
Critical vulnerability SLA compliance	Critical vulnerabilities fixed within SLA / total critical vulnerabilities	95%	Scanner and ticketing system	Vulnerability Manager	Below 90%
Critical log source coverage	Critical systems sending logs / total critical systems	95%	SIEM dashboard	SOC Manager	Below 90%
Backup restore success	Successful restore tests / planned restore tests	100%	DR test reports	BCP Manager	Any failed critical restore

Phishing failure rate	Failed users / tested users	Below 5%	Awareness platform	Security Awareness Lead	Above 8%
Supplier assurance completion	Assessed critical suppliers / total critical suppliers	90%	Vendor risk register	Procurement	Below 85%
Incident response exercise completion	Completed exercises / scheduled exercises	100% annually	Exercise reports	CISO	Missed exercise
Risk treatment overdue rate	Overdue high risks / total high risks	Below 10%	Risk register	Head of Cyber GRC	Above 10%

KPIs are intended to drive decisions. In case privileged MFA falls short of the set target, escalation by the CISO becomes imminent, due to the fact that privileged access represents a highly valuable route to exploitation for attacks. On the other hand, failure to restore from backup should be handled as a resilience problem and not just a technical one. Similarly, lack of assurance in suppliers calls for executive acceptance of the risk before onboarding or renewal. This makes the KPI model a governance tool rather than a reporting exercise. The image below shows the following KPIs are proposed governance measures for AEMO’s cybersecurity framework. The target values and dashboard figures are used as target-state indicators for board reporting and should be validated against AEMO’s actual baseline during implementation.

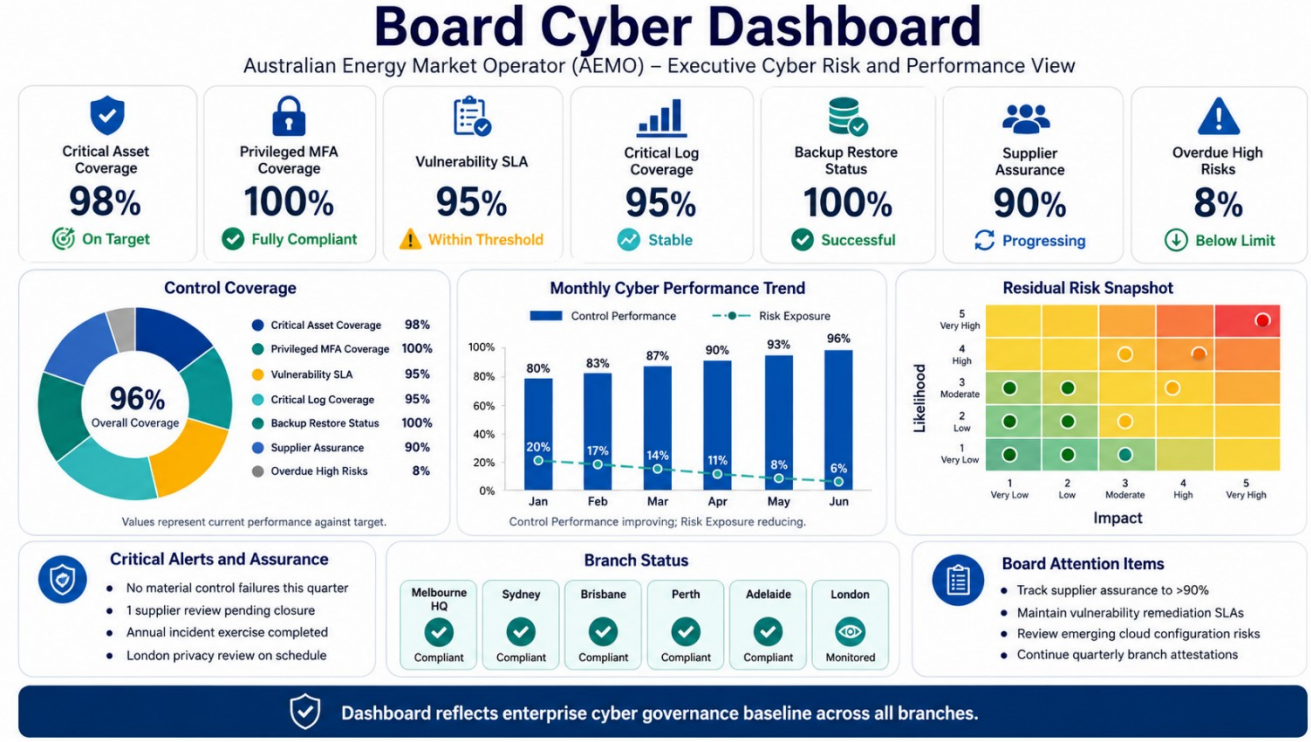


Figure 3: AEMO Executive Risk and KPI Overview

Maturity Roadmap

The maturity roadmap shows how AEMO moves from Initial to Defined and Managed maturity. It also prevents the framework from becoming a static document. Progress should be reviewed quarterly and reported to the Board of Risk and Audit Committee.

Domain	Current Initial State	6-Month Target	12-Month Target	18-Month Target
Governance	Informal or inconsistent cyber reporting	Steering committee and risk appetite approved	Board dashboard operating	Cyber risk embedded in business planning
Asset Management	Partial inventory	Critical assets identified	Automated discovery implemented	Branch attestations integrated
Risk Management	Reactive risk register	Enterprise risk method defined	Risks linked to controls and owners	Residual risk formally accepted

Policy	Inconsistent documents	Core policies approved	Branch procedures aligned	Policy compliance measured
Monitoring	Limited log visibility	Critical systems prioritized	SIEM coverage expanded	Detection use cases tuned to business risk
Incident Response	Technical response focus	CIRT/SEMT roles defined	Annual exercise completed	Lessons learned drive improvement
Supplier Risk	Contract-driven only	Critical suppliers identified	Assurance reviews underway	Supplier KPIs reported to Board
Privacy and Cross-Border Governance	Inconsistent branch treatment	London data flows identified	DPIA and transfer process implemented	Privacy controls included in audit scope

This maturity roadmap is central to the framework because it shows that AEMO is not trying to become fully mature instantly. It provides a realistic pathway from ad hoc practices to repeatable and measurable governance.

Continuous Monitoring and Ongoing Risk Management

Continuous monitoring must occur at three levels: technical monitoring, governance monitoring, and compliance monitoring. The technical category covers SIEM, EDR, vulnerability scanning, DNS queries, privileged access management, cloud posture management, and email security. The governance category covers overdue risks, policy exceptions, control attestations, supplier review, and audit issues. Finally, the compliance category covers SOCI reporting readiness, Australian privacy requirements, UK/EU privacy requirements, and supplier contractual requirements.

The AEMO must maintain a dynamic cyber risk register. Every risk must have details on business ownership, affected branch, impacted asset, threat vector, current controls, remediation plan, deadline, residual risk, and escalation point. Any risks that exceed cyber appetite must be referred to the Cyber Security Steering Committee and later to the Board Risk and Audit Committee [10], [11].

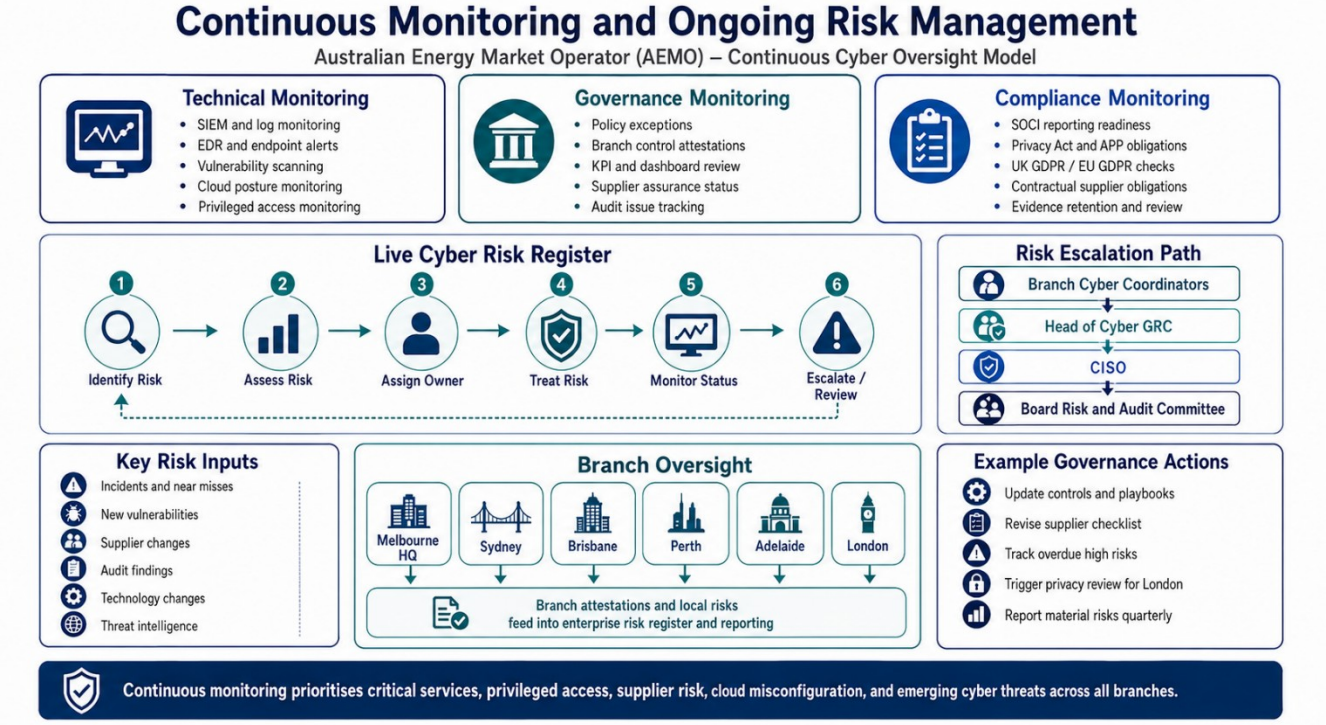


Figure 4: Continuous monitoring and risk management of AEMO

One common pitfall in governance is measuring noise rather than risk. A large volume of alerts does not necessarily mean effective security. Surveillance needs to focus on key enterprise services, privilege access, vendor access, suspicious data transfer, backup failure, cloud misconfiguration and events that impact branch and market operations.

Audit, Assurance and Continuous Improvement

AEMO should adopt a Plan-Do-Check-Act improvement cycle. Plan means defining risk appetite, policy and control requirements. Do means implementing controls across branches. Check means testing performance through KPIs, monitoring, audit and exercises. Act means remediating weaknesses, updating policies, improving controls and reprioritizing investment.

Review Activity	Frequency	Owner	Output
Cyber risk register review	Monthly	Head of Cyber GRC	Updated risk treatment status
Branch control attestation	Quarterly	Branch Cyber Coordinators	Evidence and exception report
Board cyber risk reporting	Quarterly	CISO	KPI dashboard and risk summary
Supplier assurance	Six-	Procurement and Cyber	Updated vendor risk status

review	monthly	GRC	
Incident response exercise	Annually	CISO and SEMT	Lessons learned report
Internal audit review	Annually	Internal Audit	Control effectiveness findings
Maturity reassessment	Annually	Cyber GRC	Updated maturity roadmap

Internal audit should focus on testing the effectiveness of control activities rather than the mere existence of controls. For instance, internal audit should determine if disabled user accounts have been deleted within the necessary timeframes; if any significant security threats are mitigated within SLA; if the transfer of data to the London branch was authorized; if there is successful recovery during backup testing; and if evidence has been kept by branch coordinators.

The incident response plan must incorporate teams from technical, executive, legal, communication, procurement, and branch coordinator departments. The proposed scenarios should cover the following: ransomware that affects market support systems; compromise in suppliers; breach of privacy affecting the London branch; and DDoS on the remote access system. Lessons learned should update the risk register, playbooks, policies, training and investment priorities [12].

An example of how a continuous improvement can practically be applied includes the situation when there is a problem concerning cloud misconfiguration associated with a certain third-party collaboration tool that impacts the London branch and Australian cyber teams. The supplier assessment carried out during the quarter reveals that there is excessive external share permissions granted which may result in potential leakage of information concerning the staff, suppliers, and stakeholders. According to the presented framework, such an issue is recorded in the risk register and handled by Procurement and Cyber GRC. At the same time, there is an assessment conducted by the Legal and Privacy departments regarding the Privacy Act, Notifiable Data Breaches, UK GDPR, and EU GDPR. Immediate actions are aimed at ensuring that the supplier restricts permission to external sharing and provides evidence from access logs. As an improvement measure, it will be necessary to update the supplier assurance checklist and include cloud-sharing configuration checks in vendor assessments as well as check for other SaaS solutions by branch cyber coordinators using SaaS tools, and report closure through the supplier assurance and overdue high-risk KPIs.

Conclusion

The Cybersecurity Governance Framework enables the cybersecurity capability at AEMO to be regarded as part of their enterprise risk and resilience function, and not just a technical one. The framework helps AEMO take the organization from Initial Maturity towards a more Defined and Managed state by incorporating elements such as Board level oversight, branch level responsibility for controls, critical infrastructure protection of Australia, global privacy standards, risk-based controls, and Key Performance Indicators. This approach enables AEMO to safeguard their critical assets, run their energy markets, control supplier/cross border risks, and continuously improve its cybersecurity posture as threats, technologies and regulatory expectations evolve.

References

1. Musleh, A. S., Ahmed, J., Ahmed, N., Xu, H., Chen, G., Kerr, S., & Jha, S. (2024). Experimental cybersecurity evaluation of distributed solar inverters: Vulnerabilities and impacts on the Australian grid. *IEEE Transactions on Smart Grid*, *15*(5), 5139-5150.
2. Loyd-Jones, S. L., Manwaring, K., & Berger, T. (2025). Complex regimes-regulatory overlap in Australia's cloud services sector. *Bond Law Review*, *37*(1), 105-133.
3. Rambau, T. M., Munyoka, W., Phahlamohlaka, L. J., & Kadyamatimba, A. (2026). Evaluating cyber resilience frameworks for e-government: applicability of NIST CSF, ISO/IEC 27001 and COBIT 2019 in developing country contexts. *Information & Computer Security*, 1-22.
4. Channon, M. (2019). Cyber security and data protection. In *The Law and Autonomous Vehicles* (pp. 47-63). Informa Law from Routledge.
5. Voigt, P., & Von dem Bussche, A. (2017). The eu general data protection regulation (gdpr). *A practical guide, 1st ed., Cham: Springer International Publishing*, *10*(3152676), 10-5555.
6. Lloyd-Jones, S. L. (2025). Ensuring Digital Resilience in Australia: From Resilience to Security in Critical Infrastructure Protection. In *Digital Resilience: International and Domestic Legal Responses to Cyber Security and Artificial Intelligence* (pp. 89-104). Singapore: Springer Nature Singapore.
7. Amiruddin, A., Afiansyah, H. G., & Nugroho, H. A. (2021, October). Cyber-risk management planning using NIST CSF v1. 1, NIST Sp 800-53 rev. 5, and CIS controls v8. In *2021 International Conference on Informatics, Multimedia, Cyber and Information System (ICIMCIS* (pp. 19-24). IEEE.
8. Chew, E., Swanson, M., Stine, K. M., Bartol, N., Brown, A., & Robinson, W. (2008). Sp 800-55 rev. 1. performance measurement guide for information security.
9. Dronov, V. Y., & Dronova, G. A. (2022, March). Principles of information security management system. In *Journal of Physics: Conference Series* (Vol. 2182, No. 1, p. 012092). IOP Publishing.
10. Patterson, F. D., & Neailey, K. (2002). A risk register database system to aid the management of project risk. *International journal of project management*, *20*(5), 365-374.
11. Bayuk, J. L., Healey, J., Rohmeyer, P., Sachs, M. H., Schmidt, J., & Weiss, J. (2012). *Cyber security policy guidebook*. John Wiley & Sons.
12. Sabillon, R., Serra-Ruiz, J., Cavaller, V., & Cano, J. (2017, November). A comprehensive cybersecurity audit model to improve cybersecurity assurance: The cybersecurity audit model (CSAM). In *2017 International Conference on Information Systems and Computer Science (INCISCOS)* (pp. 253-259). IEEE.

Technical Security Assurance and GRC Advisory

Australian Energy Market Operator (AEMO) | Technical assurance methodology | October 2026

Document scope: This framework defines the technical assurance programme, control tests, risk treatment rules and board reporting structure. Control conditions are assessed against agreed evidence; the document does not present untested configurations or security weaknesses as observed AEMO findings. Validation and formal adoption require authorised engagement and accountable owners.

This technical assurance framework builds on the governance structure, policy responsibilities and 18-month improvement plan. It defines evidence-based testing across identity, cloud infrastructure, endpoint protection, monitoring, recovery and AI-enabled systems. The outcomes feed into risk treatment, regulatory assurance and executive reporting. The assessment methods follow current Australian and international guidance. [S1–S9]

Application and validation. The operating model uses six locations and an Initial maturity baseline for planning. Location coverage, critical services, systems, suppliers, legal applicability and the current control baseline are confirmed during assessment mobilisation. Control effectiveness is determined through authorised testing and recorded evidence.

A. Statement of Work, Boundaries and Assurance Outputs

Engagement element	Proposed consulting scope / decision rule
Purpose	Determine whether defined security outcomes are designed and operating effectively; prioritise significant business and regulatory exposure.
In-scope technology (subject to discovery)	Identity provider and privileged access, market-supporting application interfaces, cloud tenants, backup and recovery, endpoint controls, SIEM and SOC workflows, supplier connections, AI-integrated applications, and selected OT interfaces.
Excluded until authorised	Penetration testing, changes to production configurations, intrusive OT probing, accessing live customer/personal data, and making legal representations for the organisation.
Evidence window	Recommended: current configurations plus 90 days of operation (or a risk-justified period); separate policy existence from evidence of sustained activity.
Deliverables	Evidence register; control test workpapers; NIST CSF Current/Target Profile; ASD Essentials action-by-domain ratings; risk register; regulatory applicability map; remediation plan; executive and board report.
Assurance boundaries	A defensible assessment depends on defined scope, complete evidence, permissions and corroboration; insufficient evidence is rated Not Assessed, not “Failed” or “Compliant”.
Quality gates	Independence and conflict check; approved scope; validated evidence; peer review; factual validation with owners; final risk owner sign-off; version-controlled issue log.

A1. Assessment approach

- 1. Mobilise: agree critical business services, asset boundaries, RASCI, stakeholders, contractual requirements, data-handling restrictions, and regulatory applicability with Legal.
- 2. Discover: inventory identities, systems, cloud subscriptions, network trust paths, suppliers, information flows and recovery dependencies; reconcile exports with owners.
- 3. Test design: verify the documented objective, implementation standard, approval, exception route and detection/response ownership for each control.
- 4. Test operation: select a traceable sample across branches, asset criticalities, user types and the review period; inspect live settings and independently corroborated logs.
- 5. Evaluate and challenge: record deviations; determine exploitability, affected critical service, likelihood, current/compensating controls, residual exposure and evidence confidence.
- 6. Report and follow up: issue findings with owners, dates, quick wins, funding dependencies, residual-risk acceptance and retesting conditions; provide board-level implications.

B. Australian Regulatory and Standards Applicability

The applicability matrix separates statutory duties from voluntary frameworks, contractual conditions and assurance good practice. Legal and regulatory obligations are confirmed for each entity, asset class and information-processing activity before a control conclusion is reached.

Instrument	Framework applicability	Assurance test / interpretation
SOCI Act 2018, CIRMP and reportable incidents	Potential direct legal obligations where qualifying critical infrastructure asset/responsible entity criteria are met. [S3][S4]	Confirm covered asset class, accountable entity, current CIRMP, annual reporting and incident clocks; assess 12-hour critical / 72-hour other incident pathways with Legal.
AESCSF Version 2	Energy-sector assessment and uplift framework, voluntary as a self-assessment mechanism; AEMO leads the programme. [S5]	Map current and target practices to AESCSF v2 programme and sector-relevant resilience scenarios.
ASD ISM, September 2026	Current technical control advice for IT and OT; legally binding only where another obligation/direction so provides. [S6]	Select relevant ISM controls and document design and operational evidence, deviations and tailored mitigations.
ASD Essentials, launched 15 Oct 2026	New outcome-based framework with enterprise IT, cloud and OT chapters. The older Essential Eight remains relevant for transition and contractual obligations. [S1][S2]	Assess actions in applicable domains as Not Assessed / Not Effective / Partially Effective / Fully Effective; do not convert legacy E8 maturity levels into ratings.

Instrument	Framework applicability	Assurance test / interpretation
NIST CSF 2.0	Voluntary governance and assessment structure with six functions. [S7]	Build a Current Profile, Target Profile and prioritised gap/action log; crosswalk regulatory controls without calling the NIST CSF a law.
ISO/IEC 27001:2022, ISO/IEC 27002	Voluntary/contractual ISMS and control references unless otherwise required. [S8]	Evaluate ISMS scope, leadership, risk assessment/treatment, statement of applicability, internal audit, management review and corrective action.
APRA CPS 234 and CPS 230	Generally NOT direct AEMO obligations solely because the energy sector is critical. Applicable to APRA-regulated clients. CPS 230 current amended version took effect 1 July 2026. [S9][S10]	Include a transferable APRA-regulated client overlay: information security assurance, control testing, operational resilience/tolerances and material service providers.
Privacy Act, APPs and NDB scheme	Determine organisation/processing coverage and whether notification threshold is met; avoid assuming every breach must be notified. [S11]	Inspect personal-data mapping, APP 11 safeguards, cross-border APP 8, incident assessment, notification decision record and evidence retention.
UK GDPR / EU GDPR	Applicable where UK or EU personal-data processing creates a jurisdictional connection. The London location belongs to the proposed operating model and requires confirmation.	Assess lawful basis, transfer mechanisms, retention, processor terms and breach reporting rules only if factually in scope.
AI: ISO 42001, NIST AI RMF and OWASP	Non-statutory management, risk and technical threat references, subject to jurisdiction/contract. [S12][S13][S14]	Assess AI inventory, model/data lineage, access and tool privileges, prompt-injection defences, logging, testing and incident response.

2026 watchpoint: ASD Essentials was newly published on 15 October 2026. Capture the specific edition/date used for each test, and keep Essential Eight evidence where contractual or regulatory language still requires it. [S1][S2]

C. Enterprise Technical Control Assurance Matrix

The control catalogue converts governance requirements into measurable technical criteria, defined evidence requests and repeatable assessment steps. Testing is scoped and authorised in advance, with non-intrusive approaches used for operational technology and sensitive production environments.

Control / domain	Design criteria	Expected source evidence	Operating test procedure
T01 / Identity & MFA	Privileged users protected by strong, preferably phishing-resistant MFA, distinct administrative accounts and tightly defined exceptions.	Identity policy; conditional-access export; role assignments; sign-in logs; emergency-access tests.	Reconcile 100% privileged accounts to MFA/authentication logs; sample 15 normal, 5 admin and all break-glass accounts; investigate bypasses and stale exemptions.
T02 / Joiner–mover–leaver	Access lifecycle includes ownership, approval, role design, recertification and prompt offboarding.	HR separation events, IAM provisioning logs, ticket/workflow IDs and periodic attestations.	Trace sample new starters, movers and leavers from authoritative HR records through app, cloud and vendor access; verify time-to-disable.
T03 / Cloud configuration	Cloud IAM, network exposure, secrets, storage, managed keys and audit settings meet approved secure baselines.	Cloud posture results; policy-as-code rules; tenant/subscription inventory; change logs; KMS and logging settings.	Compare deployed configurations to standard and approved exceptions; enumerate public storage, internet-exposed management paths and long-lived credentials.
T04 / Hybrid segmentation	IT/OT and inter-tenant data flows are approved, minimal, documented, monitored and reversible.	Diagrams, firewall rules, flow records, jump-host settings and approval tickets.	Walk critical data flows; sample permitted rules and deny events; review emergency paths with OT owner; no active scanning without sign-off.
T05 / Endpoint protection	EDR deployed, tamper protection enabled, sensor healthy and coverage reconciled to inventory.	CMDB/device exports, EDR health reports, detection policy, exception and alert histories.	Reconcile active hosts and EDR telemetry; sample disabled agents, legacy servers and suppression decisions; run approved harmless validation if authorised.
T06 / Detection engineering	Use cases cover priority attacker paths, are telemetry-supported and are periodically validated.	Detection catalogue; data-source map; change control; SIEM queries; test evidence and alert routing.	Select threat scenarios and confirm log generation → ingestion → parsing → rule trigger → analyst triage → closure with timestamps.
T07 / Incident response	Playbooks coordinate SOC, DFIR, cyber leadership, legal, communications and external reporting.	Incident matrix, paging roster, contact lists, exercise report, incident tickets.	Run tabletop of market-support disruption with SOCI thresholds; check decision records, escalation timing, evidence preservation and owners.
T08 / Vulnerability & patching	Asset-criticality-driven vulnerability SLAs, exception approvals and retesting.	Scanner/agent inventories; asset criticality; patch tickets; approved risk exceptions.	Sample internet-facing and high-impact vulnerabilities; confirm age, exploitability, remediation or compensating controls.

Control / domain	Design criteria	Expected source evidence	Operating test procedure
T09 / Backup & recovery	Backups are protected against compromise; RTO/RPO are business-approved and restoration is proven.	Immutable/offline backup policy, job audit trail, separate admin access, restoration records.	Inspect several recoveries for data integrity, dependencies, isolation, measured RTO/RPO and evidence of corrective action.
T10 / Third-party assurance	Material suppliers have security requirements, due diligence, monitoring and exit options.	Supplier inventory, criticality, contract annex, SOC 2/ISO reports, cloud shared-responsibility schedule.	Trace onboarding to review; assess subprocessor, incident notification, service concentration and critical operational dependencies.
T11 / Data & privacy	Sensitive market and personal data are classified, access-controlled, traceable and retained appropriately.	Data map, DLP rules, access logs, retention/disposal records, cross-border review.	Trace two critical data flows end-to-end; inspect provenance, changes, cryptography, authorised exports and incident triggers.
T12 / Operational resilience	Critical services have mapped dependencies, tolerances, disaster scenarios and tested recovery.	Business impact analysis, dependency maps, crisis exercises, DR evidence.	Challenge dependencies on identity, WAN, cloud, vendor APIs and recovery personnel; record actual outcomes without assumed percentages.
T13 / AI model & agent security	Inventory AI use; enforce model-data separation, least-privilege tools, grounded outputs and misuse controls.	Model/system cards, API gateway logs, tool allowlists, prompt injection test cases, red-team results.	Test malicious retrieved content in sandbox; check tool permissions, output controls, audit logging and response to detected misuse.
T14 / Governance & audit	Risk and control owners are explicit; exceptions have expiries; audit closure is verifiable.	Risk register, policy versions, committee minutes, assurance plan, finding closure evidence.	Trace sampled risks from finding to owner, approval, remediation evidence, retest and quarterly reporting.

D. Detailed Evidence-Led Testing Procedures

Use the workpaper ID in the finding, risk register, evidence artefact and remediation ticket. Every sample must have a documented population, date range, selection rationale and traceable identifier. A configuration screenshot alone does not prove a control operates continuously.

WP-01 | Privileged-access assurance

Assurance objective: No unmonitored standing privilege or unprotected privileged sign-in to critical environments.

Design effectiveness: Obtain approved admin role model, identity owner approvals, conditional access and break-glass exception standard.

Operating effectiveness and evidence: Export admin directory/role population and group membership; reconcile to HR and PAM records; test a representative period of privileged authentication; examine conditional-access failures, excluded principals, service identities and account reviews; retain anonymised logs. Pass only with approved coverage and credible compensating controls.

WP-02 | Cloud security posture & misconfiguration

Assurance objective: Identity permissions, storage/data exposure, audit logging and change control are risk-appropriate.

Design effectiveness: Map AWS/Azure/GCP tenancy, policies, CI/CD identities, key custody and shared-responsibility boundary; compare to documented baseline.

Operating effectiveness and evidence: Sample production and non-production tenants, internet-facing workloads, logging configurations, public objects and admin roles. Obtain export IDs/time and compare to current tickets. Record deviation if access is excessive or evidence untraceable; do not assert vendor-specific deployments without discovery.

WP-03 | Endpoint telemetry and EDR resilience

Assurance objective: Security operations can demonstrate coverage, detection and enforcement across its authorised endpoint estate.

Design effectiveness: Approved EDR/AV hardening, sensor lifecycle, exclusions and ticket triage ownership.

Operating effectiveness and evidence: Join CMDB, active DHCP/MDM/cloud inventory and EDR exports. Sample absent or stale agents, protected identities and policy deviations. Corroborate endpoint alerts with operating-system event logs and SOC case history. Use non-destructive tests only if approved and scheduled.

WP-04 | Detection efficacy and MITRE alignment

Assurance objective: Threat detections meaningfully reduce attacker dwell time, not just generate alerts.

Design effectiveness: Review critical service threat assessment, ATT&CK technique-to-data-source map, detection owner and acceptance criteria.

Operating effectiveness and evidence: Choose representative test cases such as service creation, remote execution, risky privileged sign-in and cloud credential abuse. Document exact data sources, parsing fields, expected alert, triage path, true-positive decision and response timing. Unavailable telemetry is a coverage gap, not a silent pass.

WP-05 | SOCI reporting and privacy response

Assurance objective: Material cyber disruption and potential personal-data exposure are escalated and assessed in legally appropriate timeframes.

Design effectiveness: Cross-approve a legal/regulatory decision tree with incident commander, counsel and executive roles; define time of awareness.

Operating effectiveness and evidence: Scenario-test a significant market-support outage and a separate personal-data breach; compare incident awareness, SOCI assessment, record keeping and notification draft to relevant thresholds. CISC guidance distinguishes critical 12-hour from other 72-hour pathways; OAIC decision making is separate. [S3][S4][S11]

WP-06 | Supplier, recovery and operational dependency assurance

Assurance objective: Critical operations survive credible loss or compromise of a supplier or cloud service.

Design effectiveness: Confirm critical service, supplier owner, recovery tolerances, concentration thresholds, contractual notification and test policy.

Operating effectiveness and evidence: Trace supplier credential compromise through the systems, identities, data flows and services that depend on the provider. Review concentration, alternative-service options, restoration records and executive decisions against agreed disruption tolerances.

WP-07 | AI/agent technical assurance

Assurance objective: AI components cannot access or disclose critical data or execute privileged actions beyond policy.

Design effectiveness: Require AI inventory, intended use, data classification, model onboarding, tool permission design, logging and human approval requirements.

Operating effectiveness and evidence: In an isolated test setting, evaluate prompt-injection resistance, retrieved content trust boundaries, tool-call authorisation, PII leakage, secret exfiltration paths, hallucinated operational advice, and incident triage of AI misuse. Report limitations separately from proven exposure. [S12–S15]

E. Evidence Request List and Evidence Quality Rules

Evidence ID	Requested artefact	Use / owner	Handling & validation
EV-001	Critical service map, CMDB, environment and asset scope	Architecture and operations	Verify export timestamp, asset owner and integration completeness.
EV-002	Role, privilege, MFA and conditional-access policy exports	IAM and cloud platform owner	Use read-only exports, redact principals; reconcile counts.
EV-003	Identity sign-in, PAM approval and account termination events	IAM / HR / SOC	Preserve event times/time zone and immutable IDs.
EV-004	Cloud baseline, posture exceptions, IaC scan and configuration reports	Cloud engineering	Link drift to authorised change requests and exception approvals.
EV-005	Endpoint inventory, agent health, policy and sample alert histories	Endpoint engineering	Validate host identity and last-seen timestamps.
EV-006	SIEM source inventory, parser/rule versions, retention and case tickets	Detection engineering / SOC	Check source-to-alert lineage, retention and time sync.
EV-007	Vulnerability reports, exploit context, remediation and exception tickets	Vulnerability team	Use age and asset criticality; limit exposure of sensitive findings.
EV-008	Incident response plan, exercise notes and legal escalation matrix	Incident lead / Legal	Distinguish tabletop mock data from real incident cases.

Evidence ID	Requested artefact	Use / owner	Handling & validation
EV-009	Business impact assessments, backup catalogues and restore test results	BCM / infrastructure	Compare declared objectives against test-observed recovery.
EV-010	Supplier register, contracts, attestations and dependency analysis	Procurement / vendor risk	Store third-party material under confidentiality terms.
EV-011	AI system register, gateway policies, model cards and permitted tool scopes	AI product owner / AppSec	Use dummy data for adversarial and privacy testing.
EV-012	Risk appetite, control exceptions, risk register and committee minutes	Head of GRC / executive	Check documented approver, rationale, review and expiry.

Evidence classification and assessor confidence

- Sufficient and reliable: dated machine-generated export or directly observed configuration, independently matched to an asset and operator; sampling and period disclosed.
- Partial: interview or screenshot that indicates design but does not cover population or historical operating performance. Capture limitation and seek corroboration.
- Insufficient: undocumented oral assurance, stale inventory, inaccessible raw event evidence or vendor assertion with no scope. Rating must remain Not Assessed until defensible.
- Confidentiality: obtain approval, capture only minimum records, remove credentials and personal identifiers, encrypt at rest, control distribution and honour client retention/disposal requirements.
- Independence: independent internal audit is different from management self-assessment. Label the work’s assurance level and avoid describing consultant evidence reviews as statutory audits.

F. Technical Risk Exposures and Remediation Priorities

The following control failure patterns define priorities for technical assurance. Each describes the condition to test, its business consequences, the records required to establish exposure and the control outcome that must be demonstrated before closure.

TR-01 | Privileged identity bypass

Exposure condition: An excluded cloud administrator identity retains a standing role and a legacy authentication path. Business risk: Unauthorised privileged access can threaten market-data integrity and enable lateral movement across trusted services.

Validation evidence: EV-002/003 — privileged role assignments, authentication exclusions, sign-in events and documented compensating controls.

Control treatment: Remove unnecessary standing privilege; enforce phishing-resistant MFA; secure and monitor emergency identities; verify 30 days of sign-in records. Accountable role: IAM Lead. Priority window: 0–30 days after confirmation.

TR-02 | Critical telemetry gap

Exposure condition: A critical internet-facing service has no current SIEM ingestion or source-health record. Business risk: Intrusion and unauthorised changes can go undetected, delaying investigation and regulatory notification decisions.

Validation evidence: EV-001/006 — critical service inventory, expected log-source register, ingestion timestamps and alert dependencies.

Control treatment: Onboard required events; test parsing and end-to-end alert delivery; assign source-health SLOs and escalation ownership. Accountable role: SOC Manager. Priority window: 0–30 days after confirmation.

TR-03 | Supplier access concentration

Exposure condition: A supplier uses persistent, broad service credentials across sensitive integration workflows. Business risk: Compromise of the supplier may propagate across services and undermine segmentation and operational resilience.

Validation evidence: EV-002/010 — service identity scope, credential storage and rotation records, provider contracts, access logs and continuity dependencies.

Control treatment: Rotate and restrict credentials; isolate permissions per service; monitor use; strengthen incident-notification obligations. Accountable roles: Vendor Risk and IAM. Priority window: 31–90 days after confirmation.

TR-04 | Recovery objective without demonstrated restoration

Exposure condition: The business continuity plan defines a four-hour recovery time objective, but end-to-end restoration has not been demonstrated. Business risk: A major outage may exceed approved tolerances even where backups report successful completion.

Validation evidence: EV-009 — application-consistent restore results, critical dependency checks, timestamps and business recovery approvals.

Control treatment: Run an isolated service restoration; record actual recovery results; reconcile dependencies and business impact analysis; address gaps. Accountable role: BCM/Infrastructure. Priority window: 31–90 days after confirmation.

TR-05 | Detection rules without validation

Exposure condition: Enabled detection rules have no documented mapping to required event sources or repeatable test cases. Business risk: Alert volumes may give false confidence while material attack paths remain unobserved.

Validation evidence: EV-005/006 — prioritised ATT&CK behaviours, log sources, detection content, alert histories and end-to-end validation runs.

Control treatment: Establish detection-as-code acceptance tests, version control, false-positive review and measured threat coverage. Accountable role: Detection Lead. Priority window: 31–90 days after confirmation.

TR-06 | AI-enabled tool action outside least privilege

Exposure condition: An AI assistant may call an operational API based on untrusted retrieved content without independent authorisation. Business risk: Prompt injection could cause unauthorised changes or disclosure where tool permissions extend beyond the user's approved scope.

Validation evidence: EV-011 — tool scopes, policy-gateway decisions, approval records and safe tests using non-production services and synthetic data.

Control treatment: Enforce deterministic authorisation, data provenance, scoped API credentials, approval of high-impact actions and AI abuse monitoring. Accountable role: AI Product Owner. Priority window: 0–30 days after confirmation.

TR-07 | Control exceptions without review and expiry

Exposure condition: Control deviations remain open without an accountable risk owner, expiry or retesting plan. Business risk: Exceptions become permanent, reducing assurance confidence and obscuring material exposure in executive reporting.

Validation evidence: EV-012 — exception register, approvals, compensating controls, expiry dates and escalation history.

Control treatment: Assign a risk owner and expiry; document temporary safeguards; review at least every 90 days and track closure. Accountable role: GRC Manager. Priority window: 31–90 days after confirmation.

G. Risk Assessment Method, Register and Treatment Logic

The assessment uses a five-point likelihood scale and a five-point business-impact scale. Inherent risk is calculated before additional treatment; target residual risk reflects the intended position after remediation. Approved control evidence, business risk appetite and accountable-owner decisions determine the final recorded ratings.

Score	Classification	Proposed escalation / decision
1–4	Low	Asset owner records; review at normal risk cadence.
5–9	Moderate	Control owner and GRC manager assign treatment and due date.
10–15	High	CISO review; remediation or formal time-bound acceptance by authorised business risk owner.
16–25	Extreme	Urgent executive escalation; critical service owner approves interim restriction, recovery or compensating control.

Risk pattern for planning	Inherent planning L×I	Target residual after validation	Risk owner / treatment & re-test
R-01: Privileged admin bypass	4×5 = 20 (Extreme)	2×5 = 10 (High) after verified MFA/PAM	IAM + Critical Service Owner; eliminate bypass, demonstrate sign-in enforcement; evidence WP-01.

Risk pattern for planning	Inherent planning L×I	Target residual after validation	Risk owner / treatment & re-test
R-02: SIEM blind spot for a critical service	4×4 = 16 (Extreme)	2×4 = 8 (Moderate) after test alert and source health	SOC Manager; service ingest + rule validation; evidence WP-04.
R-03: Supplier cross-service credentials	3×5 = 15 (High)	2×5 = 10 (High) after scoped access and monitoring	Vendor Risk/Service Owner; contract change + IAM restriction; evidence WP-06.
R-04: Unproven recovery target	4×5 = 20 (Extreme)	2×5 = 10 (High) after witnessed restore	BCM Manager; implement and observe full recovery; evidence WP-06.
R-05: AI tool prompt injection	3×5 = 15 (High)	2×5 = 10 (High) after tool gate and test	AI Product Owner; sandbox validation + approval control; evidence WP-07.

Risk-rating control: The planning scores below support treatment prioritisation. The register cannot treat target scores as observed reductions until mitigations are implemented, independently tested and approved by the designated risk owner.

Risk record minimum schema

- Risk ID; critical service and asset; causal threat/weakness; affected information/operations; evidence IDs; inherent likelihood and impact; tested existing controls; detection/recovery consequences; residual likelihood/impact; legal obligations; owner; treatment option; date; risk acceptance authority; verification test.
- Document the treatment decision as mitigate, avoid, transfer or accept. No governance template by itself creates control effectiveness; closure requires verification that the security outcome is achieved.

H. Technical-to-Regulatory Assurance Crosswalk

Technical issue / domain	Relevant baseline	Business / compliance assurance narrative
Admin MFA / privileged access	ASD Essentials (enterprise IT/cloud), ISM, ISO 27001 access control, NIST PR.AA	An identity bypass can be a gateway to compromise of high-criticality services; test both privileged population coverage and sign-in enforcement. [S1] [S6][S7]
Cloud tenant drift	ASD Essentials cloud, ISM and NIST PR.PS / ID.AM	Risk arises when approved baselines differ from deployed IAM, network, secret and storage settings; assess scope and change history. [S1][S6]
SIEM and detection operations	ASD Essentials visibility and response, NIST DE, AESCSF	A logging policy is insufficient if critical sources do not generate ingested, parsed and actioned security events. [S1][S5][S7]

Technical issue / domain	Relevant baseline	Business / compliance assurance narrative
Supplier and SaaS assurance	ISO 27001 supplier controls, NIST GV.SC, SOCI supplier/data-service duties where applicable	Concentration and inherited cloud security controls require contractual, technical and recovery evidence. [S3][S7][S8]
Operational resilience and recovery	CIRMP where applicable; AESCSF; NIST RC; CPS 230 for APRA clients	Relate restore results and dependencies to tolerated critical-operation disruption, not backup success alone. [S4][S5][S9]
Endpoint hardening and patching	ASD Essentials, ISM and retained E8 evidence if required	Patch cycle, anti-malware/EDR and application control need measured coverage and bypass exception governance. [S1][S2][S6]
AI system and agent security	ASD Essentials AI governance; ISO 42001; NIST AI RMF; OWASP LLM Top 10	Show where untrusted prompt/retrieval content crosses privilege and data boundaries; document misuse response. [S1][S12][S13][S14]
Privileged and service-provider risks in finance clients	APRA CPS 234 and CPS 230 (only where regulated)	For APRA-regulated entities, test information security capability, control assurance and materially disruptive supplier/operational risks. [S9][S10]

I. Cloud, Hybrid, OT and AI Technical Architecture Review

I1. Market-data trust-boundary review

Map the market-data exchange across this sequence: market participant or supplier → API gateway → application identity → message broker → processing service → storage/analytics → monitoring and recovery services. Review the trust boundaries at which privileged access, data integrity, dependencies or event visibility can fail.

- Identity plane: map workforce admin, application service principals, managed identities, federation, PAM, break-glass and third-party roles. Confirm service identities cannot inherit broad human administrative privileges.
- Network/control plane: diagram internal/external access paths, firewall trust zones, service endpoints, privileged management paths, DNS and update distribution; inspect segmentation enforcement and approved emergency access.
- Data plane: map data classification, signed/integrity-checked market messages, immutable audit events, source provenance, transport encryption and administrator-level modification monitoring.
- Telemetry plane: record each significant control-plane and data-plane event, log integrity/retention, attack test alerts, incident routing and OT-specific safety/performance limitations.
- Resilience plane: catalogue cloud/provider region failure, identity unavailability, supplier API outages, corrupted queues, recoverability of secrets and logging; assess graceful degradation and restoration evidence.

I2. Operational technology (OT) safety and scoping

Assess systems that interact with physical operations using OT-aware, non-intrusive methods and approved maintenance windows. NIST SP 800-82 Rev. 3 documents OT safety and reliability considerations, and ASD published an OT chapter of the Essentials in October 2026. The asset boundary and actual OT dependencies must be verified during scoping. [S1][S16]

- Require formal owner/safety approval before any active discovery; favour existing asset inventories, read-only configuration reviews, passive telemetry and witnessed tabletop scenarios.
- Test separation of business IT and OT-management paths, jump-host MFA, vendor remote maintenance, backups, incident decision authority and emergency change approvals.

I3. AI assurance checkpoints

AI layer	Practical assurance test	Acceptable evidence / red flags
Governance / inventory	Register model, supplier, use case, data sensitivity, human accountability and legal basis.	Versioned system card, use-case approval; flag undocumented autonomous use.
Data handling	Verify input/output classification, training-use restriction, retention, redaction and data residency.	DPAs, API gateway policy, DLP logs; flag sensitive prompts delivered to unmanaged third parties.
Identity / secrets	Examine model-service identity and tool scopes, secret access and separation of duties.	IAM policy, token rotation, vault audit; flag all-powerful persistent API keys.
Prompt / retrieval security	Use controlled indirect prompt-injection scenarios from untrusted documents and model outputs.	Test transcripts, content trust annotations; flag compliance decisions delegated to untrusted text.
Agent action safety	Require deterministically scoped tool calls, validation, human confirmation for material changes.	Tool allowlists, policy decisions, approval logs; flag high-privilege autonomous execution.
Monitoring / response	Log prompts safely, tool invocations, denied calls, data disclosure attempts and rollback actions.	Privacy-aware audit trail and AI misuse playbooks; flag unobservable tool actions.
Validation / change control	Repeat adversarial and regression testing after model, prompt, retrieval or tool changes.	Test suite, red-team outcomes, release approvals and owner acceptance.
Oversight / legal	Map NIST AI RMF Govern-Map-Measure-Manage to AI system lifecycle and ISO 42001 governance.	Named accountable AI owner, impact assessment, review board and change ledger. [S12][S13]

J. Cybersecurity Maturity, Gap Analysis and Roadmap

The original 18-month roadmap remains the proposed planning horizon. Technical assurance should support it with a NIST CSF Current and Target Profile, AESCSF evidence, ASD Essentials ratings by action and domain, ISO 27001 ISMS findings, and evidence of any applicable legal duties. These are separate views of the same risks, not interchangeable compliance scores. The first stage is to establish a reliable baseline. [S1][S5][S7]

Workstream	Day 0–30	Day 31–90	Month 4–9	Month 10–18
Governance / evidence	Confirm scope, risk appetite, responsible entity, data map	Approve evidence catalogue, legal register, control owners	Run quarterly attestations / peer-reviewed tests	Reassess and fund exceptions to closure
Identity / cloud	Inventory privileged accounts and internet-exposed controls	Remove uncontrolled admin paths; close severe posture gaps	Implement continuous cloud drift and quarterly access review	Verify sustained control effectiveness
Detection / endpoint	Reconcile SIEM/EDR sources to critical services	Validate high-risk ATT&CK pathways end-to-end	Automate detection regression and response exercises	Threat-led assurance and trend reporting
Suppliers / resilience	Identify material services and single points of failure	Sample contract controls and witness restore test	Improve exit options and recovery exercises	Independent resilience retest
AI / emerging technology	Compile AI and model/agent register	Apply tool-action, privacy and logging guardrails	Expand red-team scenarios and controlled testing	Integrate AI risks into standing GRC cycle
OT and critical infrastructure	Validate scope and maintenance approval requirements	Establish passive evidence and access-review plan	Run tabletop exercises aligned with operational tolerance	Reassess cross-domain resilience

KPI definitions and starting performance targets

Indicator & calculation	Suggested starting target	Evidence and executive interpretation
Verified privileged MFA = protected accounts / privileged accounts	100%; any critical bypass escalated	IAM policy + sign-in events; reflects route to takeover, not user convenience.
Critical detection coverage = tested top threats / prioritised threats	≥90% by agreed programme milestone	Evidence-linked rule test cases; avoids counting enabled rules as effective.

Indicator & calculation	Suggested starting target	Evidence and executive interpretation
Log freshness = critical log sources received within SLO / expected critical sources	≥98% per reporting period	Ingestion timestamps and asset register; flags risk of operational blind spots.
Critical assets with healthy EDR = present and healthy / eligible critical assets	≥98%, documented exceptions	Endpoint/CMDB join; measure gaps by critical service.
High-risk findings overdue = unresolved past due / total high-risk findings	≤10%, trending down	Approved treatment dates and retest outcomes; flags governance drift.
Recovery validation = witnessed successful end-to-end service restores / scheduled tests	100% tested, record actual RTO/RPO	BCP test trace; an “all backups green” metric is insufficient.
Supplier assurance coverage = current validated reviews / material suppliers	≥95% by defined cycle	Supplier and service-owner attestation; escalates concentration risk.
AI control validation = evaluated in-scope AI use cases / inventoried AI use cases	100% high-impact use cases	Red-team evidence and tool audit trail; visibility of emerging technology exposure.

K. Risk and Control Assessment Workshops

K1. Ninety-minute material-risk and control-effectiveness workshop

Time	Activity	Facilitation output
00–10 min	Confirm scope, critical services, system owners and assessment dependencies.	Agreed assessment boundaries and unresolved inventory questions.
10–25 min	Identify priority threat scenarios: identity takeover, vendor compromise, market-data integrity, destructive malware.	Business-impact narratives and control owners.
25–45 min	Review identity, cloud, endpoint, detection and backup control design against expected outcomes.	Selected test population, exceptions and evidence owners.
45–65 min	Test incident notification, emergency decisions and recovery ownership through a structured table-top exercise.	Escalation trigger, reporting and continuity gaps.
65–80 min	Assign inherent risk, existing controls, likelihood/impact and treatment options.	Draft risk records, treatment criteria and accountable owners.

Time	Activity	Facilitation output
80–90 min	Close with executive decisions, dates, governance cadence and factual-validation steps.	Decision log and sponsor-ready summary.

K2. Facilitator challenge questions

- If a third-party managed identity is compromised on Friday evening, which two business processes are affected first, and how do we prove that?
- Which actual events in the SIEM would distinguish privileged abuse from permitted emergency access, and who receives the alert?
- What demonstrates that a high-severity control has worked every day over the last 90 days rather than only on the day of the audit?
- What are the business-approved tolerance, actual last measured recovery time, and supplier dependencies for the highest-criticality service?
- Where is the boundary between AI-generated advice and authorised execution, and what prevents prompt-injection from crossing it?
- Who signs off on residual risk and what happens when the requested treatment date would exceed risk appetite?
- When does a security event become a reportable SOCI incident, an NDB assessment, or a CPS 234 issue for a regulated client?

L. Proposed Policy, Standards and Control Statements

The governance policy suite is supported by the following testable control statements. Adoption requires the relevant policy owner’s approval, assignment of control responsibility and clear arrangements for handling and reviewing exceptions.

POL-IAM-01 — Privileged access

All standing and just-in-time privileged access to critical services must be owned, approved, logged, MFA protected and reviewed at least quarterly. Emergency identities require separate custody, restricted use, after-action review and monitored sign-in. Any exception requires named risk-owner approval and a defined expiry.

STD-CLD-02 — Cloud configuration

Each production cloud account/subscription must have a security owner, tagged service criticality, baseline configuration checks, least-privilege policy, central audit logs, protective access boundaries and remediation tracking for deviations. Exposed management paths require documented risk treatment.

STD-SOC-03 — Telemetry and detections

Every material service must have a documented logging owner, expected security event catalogue, log transport and retention requirements, monitored freshness threshold, and validated detection use cases for its credible attack paths.

STD-AI-04 — AI services and agents

No AI model or AI-enabled agent may invoke privileged actions or transmit sensitive information outside approved boundaries without deterministic access enforcement. High-impact actions require explicit authorised approval and traceable records; untrusted content is not a source of permissions.

STD-BCM-05 — Resilience testing

Every critical service must define an approved recovery target and perform a risk-based end-to-end restoration exercise that includes dependencies. Failed or untested recoveries require risk register entry, owner, interim treatment and retest.

PROC-RSK-06 — Exception lifecycle

An exception record must specify asset, control, justification, compensating control, inherent/residual risk, approver, expiry and objective evidence for closure. Expired exceptions must be escalated, not automatically renewed.

M. Executive and Board Assurance Reporting

Executive reporting protocol: Status and control-effectiveness ratings are supported by reviewed source evidence. The board report identifies material assurance questions, accountable owners, remediation decisions and outstanding verification requirements.

Executive decision summary

Board reporting should establish whether essential services can be protected and restored, rather than simply confirm that policies or tools exist. The first assurance cycle addresses three questions: Are privileged restrictions enforced across critical services? Can the SOC produce usable alerts for prioritised threat behaviours? Has recovery been demonstrated within business-approved tolerances? Findings are ranked by service impact, regulatory exposure and the decision required.

Priority assurance domain	Required assessment evidence	Decision or action required
High-impact privileged access	Privileged role population, conditional-access rules, authentication events and approved emergency-access exceptions.	Commission population-wide MFA/PAM review and approval of exceptions.
Critical service detection coverage	Critical service register, expected data sources, ingestion health, detection rules and end-to-end test results.	Sponsor SIEM inventory reconciliation and independent scenario validation.

Priority assurance domain	Required assessment evidence	Decision or action required
Recoverability of market-supporting systems	Business-approved RTO/RPO, service dependencies, restore logs, elapsed recovery time and exercise sign-off.	Require a witnessed, safe, end-to-end restore with recorded actual tolerance.
Material supplier concentration	Material supplier list, concentration analysis, contract obligations, access scopes and continuity testing.	Identify single points of failure and contract/exit restrictions.
AI-assisted operational decisions	AI use-case register, tool permission map, approval records, adversarial test evidence and activity logs.	Require inventory, owner approval and independent prompt/tool security testing.

Three decision requests to the executive / board sponsor

- Approve a staged, risk-based assurance programme with named critical service sponsors, read-only evidence collection and the right to challenge previously undocumented exceptions.
- Authorise remediation of any subsequently verified extreme/high exposures and require accountable business owners to formally review residual risk against approved appetite.
- Mandate quarterly evidence-led reporting with tested outcomes, trend lines, remediation ageing, resilience exercises and explicit “not assessed” disclosures.

N. Assurance Deliverables and Supporting Evidence

This map links assurance outputs to the controls, test procedures, evidence requests and reporting sections within the framework. It supports review consistency and gives technical and business stakeholders a clear route from assessment scope to treatment decisions.

Proposed assessment output	Supporting workpapers and methods
Cloud, hybrid and AI security review	Sections C, D, I: cross-environment trust boundaries; cloud policy drift tests; agent privilege and prompt-injection workpapers.
Control design and operating effectiveness assessment	Sections A, C, D, E: test criteria, samples, time-bound logs, population completeness, evidence confidence and result ratings.
Identity, endpoint and threat-monitoring assessment	Control set T01–T08 and workpapers WP-01 through WP-04 with concrete data sources and test steps.
Governance, risk and maturity assessment	Sections B, G, H, J: legal applicability, NIST Current/Target approach, ASD Essentials, risk calculations and roadmap.

Proposed assessment output	Supporting workpapers and methods
Australian regulatory and standards applicability review	Section B distinguishes direct SOCI obligations, voluntary/contractual standards and APRA-only client overlays.
Facilitated risk and control workshop	Section K agenda, prompts, decisions and example follow-up outputs; Sections D–G workpapers and risk records.
Draft policies and operational controls	Section L produces six testable control statements with named verification expectations.
Executive and board reporting pack	Sections F/G translate findings to business impact; Section M provides a non-misleading, board-ready decision brief.
Critical infrastructure and operational technology review	SOCI obligations; AESCSF v2; NIST SP 800-82 OT constraints; market-service business impacts.
Quality review and method improvement	Section O gives reusable QA, analyst mentoring and assurance delivery cadence.

O. Assurance Quality Review and Capability Development

O1. Standard consulting delivery controls

- Scope gate: signed objectives, technical scope, permissions, evidence handling and conflict-of-interest declaration before any assessment activity.
- Workpaper gate: each finding must reference risk scenario, asset, test ID, evidence IDs, timestamp, population/sample, expected outcome, observed result, limitation and peer-review record.
- Challenge gate: technical lead assesses whether the evidence supports the finding, whether a compensating control was missed, and whether business impact statements are proportionate.
- Reporting gate: distinguish independently observed facts, assessor analysis, legal interpretation referred to counsel and risk modelling; validate factual accuracy with service owners before issuing a final report.
- Remediation gate: named owner, effort/dependency, approved target, risk acceptance where necessary, independent retest and quarterly board tracking.

O2. Analyst mentoring plan

A repeatable analyst development programme covers privileged access sampling, SIEM event-to-alert validation, supplier disruption reviews and writing technical findings for executive audiences. Assessors complete evidence records, peers review test sufficiency, and the technical lead confirms that actions address defined business risks. Training records use synthetic or approved anonymised data.

O3. Reusable assets for GRC, DFIR and MDR assurance teams

- Control test library mapped to ASD Essentials, ISM, NIST CSF and ISO 27001 outcomes; edition-controlled and versioned.
- Automated (read-only) asset-to-EDR and asset-to-SIEM coverage reconciliation for client-owned inventories.

- Detection assurance worksheet connecting telemetry, adversary behaviours, analytic rules, SOC runbooks and incident case outcomes.
- AI risk assessment template evaluating prompt injection, data governance, tool-use permissions and defensive telemetry.
- Board scorecard that presents tested outcomes, unanswered questions, exception ageing and material business service exposure rather than alert volume.

P. Additional References

The supporting assessment methods draw on the following official sources, reviewed in October 2026. The original report's References (1–12) are retained separately.

[S1] Australian Signals Directorate, "ASD Essentials: evolving our approach to cyber security resilience" (15 October 2026). https://www.cyber.gov.au/news/asd-essentials-evolving-our-approach-to-cyber-security-resilience

[S2] ASD, "Transitioning from the Essential Eight" and "Assessment process guide" (15 October 2026). https://www.cyber.gov.au/publication/transitioning-from-the-essential-eight

[S3] Critical Infrastructure Security Centre, "SOCI Act regulatory obligations". https://www.cisc.gov.au/how-we-support-industry/regulatory-obligations

[S4] CISC, "Notification of Cyber Security Incidents Guidance". https://www.cisc.gov.au/resources-subsite/Documents/ncsi-guidance.pdf

[S5] AEMO, "AESCSF framework and resources" (includes AESCSF v2 Core and tools). https://www.aemo.com.au/initiatives/major-programs/cyber-security/aescsf-framework-and-resources

[S6] ASD, "Information Security Manual" (September 2026). https://www.cyber.gov.au/ism/2026-09

[S7] NIST, "Cybersecurity Framework 2.0: Organizational Profiles". https://www.nist.gov/cyberframework/profiles

[S8] ISO, "ISO/IEC 27001:2022—Information security management systems". https://www.iso.org/standard/27001

[S9] APRA, "CPS 230 Operational Risk Management" (in force 1 July 2026). https://www.apra.gov.au/standards/cps-230

[S10] APRA, "CPS 234 Information Security". https://www.apra.gov.au/standards/cps-234

[S11] OAIC, "Quick reference guide for responding to data breaches" (29 June 2026). https://www.oaic.gov.au/privacy/notifiable-data-breaches/quick-reference-guide-for-responding-to-data-breaches

[S12] ISO, "ISO/IEC 42001:2023—AI management system". https://www.iso.org/standard/42001

[S13] NIST, "AI Risk Management Framework: Generative AI Profile" (AI 600-1). https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence

[S14] OWASP, "Top 10 for LLM and GenAI". https://genai.owasp.org/initiatives/top-10-for-llm-and-genai/

[S15] ASD, "AI considerations within the Essentials" (October 2026). https://www.cyber.gov.au/publication/ai-considerations-within-the-essentials

[S16] NIST, "SP 800-82 Revision 3: Guide to Operational Technology Security" (final 2023). https://csrc.nist.gov/pubs/sp/800/82/r3/final

[S17] ASD, "Essentials for OT" (15 October 2026). https://www.cyber.gov.au/publication/essentials-for-ot

[S18] ASD, "Essentials for cloud" (15 October 2026). https://www.cyber.gov.au/publication/essentials-for-cloud